



Information Technology Law: The Law and Society (5th edn)

Andrew Murray

p. 593 22. Data protection: the legal framework

Andrew Murray

<https://doi.org/10.1093/he/9780192893529.003.0022>

Published in print: 08 June 2023

Published online: August 2023

Abstract

This chapter examines data protection, digitization of data, its implications for personal privacy, and the regulation of data industries. It begins by discussing the current law found, post Brexit in the UK General Data Protection Regulation and the Data Protection Act 2018. It examines the key concepts of data controllers, data processors, and data subjects, and discusses the conditions for the processing of personal data. This includes an examination of key cases such as *Nowak v Data Protection Commissioner*, the *Facebook fan page* case, and *Bodil Lindqvist*. It looks at the geographical scope of UK GDPR and the extra-territorial effect of the Regulation and examines the domestic purposes exemption after *Ryneš*. It examines questions of fairness and lawfulness of processing as discussed in *Johnson v Medical Defence Union*.

Keywords: digitization, data subjects, data controllers, personal privacy, data protection, data processing, General Data Protection Regulation, UK GDPR

The theme of this book is that the information society divorces identity from the physical person, and as more of our everyday lives are ordered digitally, we increasingly use proxy data to identify us. In addition, we generate vast amounts of personal information as we ‘surf’ or trail through this digital environment. By our actions we reveal our location including where we live and where we work; we reveal our preferences for food, clothing, entertainment, and travel; we even reveal our sexuality, our family connections, our loves, and our religious beliefs. We can reveal our innermost secrets: do we support or object to a right to choose an abortion? Were we a Remainer or a Leaver? Do we support or object to open borders and the free movement of persons?

The risks of misapplication, mishandling, or misprocessing of data in this ‘data-driven’ environment cannot be understated. Risks extend from something as simple as failing to secure data, a charge laid before the UK government at several points during 2007 as they in quick succession lost data relating to 25 million child benefit recipients,¹ 3 million candidates for the driving theory test,² 168,000 NHS patient records,³ and

40,000 housing benefit claimants;⁴ to bias and errors caused by data that is inaccurate, incomplete or out of date, leading to an unfair outcome in computerized (or even human) decision making processes.⁵ Or more simply with money to be made from data mining our data may be packaged and sold, or otherwise transferred against our wishes, to third parties for purposes such as profiling and marketing.⁶ These (and more) risks will form the focus of this chapter and the next.

p. 594

22.1 Digitization, data, and the regulation of data industries

Digital information is more valuable than analogue information as it may be manipulated and processed in conjunction with other data to reveal hidden patterns and truths, a process known as data analytics. As a result, a multi-billion pound industry has grown up around data.

Some data analytics companies, such as Experian, gather data to act as an adviser to others. Experian is the world's largest credit reference and scoring agency. It ingathers data from a variety of sources such as records held by lenders, the electoral roll, and the list of County Court judgments. It then uses this data to give a numerical score to the risk of lending to an individual. All credit agencies from mortgage lenders and credit card issuers to local shops which offer credit, use their services, or the services of one of their competitors to determine whether to extend credit to individuals.

Other companies gather data to improve their service to their customers. Examples of such schemes include customer loyalty cards such as the Tesco Clubcard and the Nectar Card. They gather data on customer buying habits and allow the retailer to tailor their stock and staffing levels accordingly as well as offering customers rewards such as discount vouchers and promoting related goods and services.

A third type of company carries out market research using gathered data with a view to selling their insights, or tailored advertising products, to clients. These include market research companies like Brand Institute and Nielsen, but more likely today will be the global internet giants; Google being a leading provider in this area. Google gathers vast amounts of search and passive tracking data and then sells specialist online advertising (Google Ads) which are much more focussed on the target market than traditional media advertising. By offering this service Google has become the largest media advertising company globally, the only other company even coming close to Google's ad pull being Facebook owner Meta.⁷

Fourth, there are companies who act as information brokers for others. They gather information and sell it on as packaged data for the purposes of product development, advertising and promotion, or other purposes. This may include social networking sites such as Meta/Facebook, mobile network operators like Vodafone or hardware suppliers like Apple or Samsung. Or it may be specialist information gatherers such as tracking companies Oracle Advertising or Acxiom who gather data on internet habits and then sell that information on to third parties.

Finally, there are the organizations on the fringes of what is legal. These are groups that gather data to create massive databases of customer details including mailing lists, email lists, and phone lists. These are then used for direct mailing or cold calling to try to sell goods and services. Some organizations involved in this industry are responsible and act legally, such as Marketing File, Electric Marketing, or even BT. Others

p. 595 though are less responsible and exist at the fringes of what is required under the UK's ↵ implementation of the General Data Protection Regulation (known as UK GDPR) and the Data Protection Act 2018.

All these companies want personal data. It is the lifeblood of their operations, but it is costly to gather and process. As a result, processes have been developed to make it easier and cheaper to ingather and store such data, but automation of data gathering risks our data privacy. A strict legal regime is required to regulate the industry. This regime must ensure that when data is gathered individuals are aware of what data is being gathered, why it is being gathered, and how it will be stored. It must ensure that there are standards within the industry to safeguard data is accurate, up to date, secure, and fairly processed. Further, it must guarantee that if sold or transferred, data remains protected and cannot be sold or transferred for reasons unconnected with its original gathering. Finally, there must be an enforcement procedure to ensure all these things are done and that there is oversight of the industry as a whole.

22.1.1 The changing face of data protection laws in Europe

There is a long history of data protection legislation in Europe dating back to the *Hessisches Datenschutzgesetz*, the original data protection law passed in the German state of Hesse in 1970 and the Swedish *Datalagen*, the first national data protection law, passed in 1973. European data protection law was eventually harmonized as a result of the Data Protection Directive 1995,⁸ as given effect in the UK through the Data Protection Act 1998.

More recently, European data protection law has been comprehensively reviewed and modernized. When the Charter of Fundamental Rights of the European Union⁹ was agreed in 2000 EU citizens gained a new fundamental right: the right to the protection of personal data concerning him or her.¹⁰ When the Charter became part of the EU legal settlement in December 2009,¹¹ the view from the Commission was that the state of data protection law at that time did not meet the fundamental right standard. As a result, they issued a citizen factsheet explaining why reform of data protection law was necessary:

the current rules need to be modernised – they were introduced when the Internet was still in its infancy. Rapid technological developments and globalization have brought new challenges for data protection. With social networking sites, cloud computing, location-based services and smart cards, we leave digital traces with every move we make. In this 'brave new data world' we need a robust set of rules. The EU's data protection reform will make sure our rules are future-proof and fit for the digital age.¹²

To implement the necessary changes EU Commission Vice-President Viviane Reding published specific proposals to reform European data protection rules, including a draft for a new Data Protection Regulation.¹³

p. 596 ↵ The need for a new framework was apparent: the Data Protection Directive 1995 had been drafted and negotiated in the period 1992–5. This was before the modern internet, smartphones, social media platforms, and data giants such as Google and Facebook. The CJEU had been forced to sometimes take expansive and creative interpretations of the law to make it fit for the modern world.¹⁴ In addition, as a Directive the law had been subject to divergent interpretation both in implementing legislation and by domestic courts meaning that it was no longer the unified regime it was intended to be. The General Data Protection Regulation (GDPR)

was to correct this but was subject to extensive delay and renegotiation. An almost complete version of the text was agreed in December 2015, following the successful conclusion of six months of trialogue negotiations between the Commission, the European Parliament, and the Council of the European Union.¹⁵ The text was finally agreed and adopted in May 2016 and came into force two years later on 25 May 2018 as the General Data Protection Regulation (GDPR).¹⁶

The Regulation harmonized and extended data protection rights. The real strength of the new law though is the way it was enacted. As a Regulation rather than a Directive it creates a binding legal regime for all EU Member States, sweeping away the fragmented approach of the old Data Protection Directive. In the 21 years since the Directive had been promulgated the business of data gathering and processing had changed beyond recognition. The arrival of e-commerce and social network platforms, along with online tracking and data gathering technologies meant that an online business, or indeed any business with an online presence was likely to be found to be gathering data in all EU Member States simultaneously and thereby likely to be subject to the controls of 28 different national data protection regimes and authorities. The driving force behind the Regulation was twofold: (1) to ensure non-EU companies, such as Tumblr, were subject to EU data protection regulation when they target or process the data of EU citizens; and (2) to ensure companies established in the EU such as Google (whose European Headquarters are in Dublin) and Facebook (also Dublin) could submit themselves to the supervision of one local supervisory authority and know they are in compliance with EU data protection law across the Union. When the new law came into effect in May 2018 you may have noticed its effect even if you didn't know why as websites and other digital service providers asked you to reconfirm your permissions or to check and reconfirm your cookie settings.

22.1.2 GDPR and Brexit

Before moving on we must address the impact of Brexit on the UK data protection framework. The UK formally left the EU on 31 January 2020 and from that date the GDPR has not been part of UK law. However, the need for a strong data protection framework for UK citizens, and the need for UK businesses to continue to trade with EU businesses meant that there was an incentive to retain much of the GDPR framework. As a result, much has been done to retain the provisions and scope of GDPR in UK law.

p. 597 First, the UK has retained the majority of GDPR provisions in a framework known as UK GDPR. This is the retained version of EU GDPR and forms part of UK law by s.3 of the European Union (Withdrawal) Act 2018 and Sch.1 of the Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019. It is defined in s.3(10) of the Data Protection Act 2018 as 'Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data as it forms part of the law of England and Wales, Scotland and Northern Ireland'. This means that, pending proposed amendments to UK GDPR in the Data Protection and Digital Information Bill,¹⁷ it is safe to refer to provisions of GDPR post Brexit.

Second, the prior jurisprudence of the CJEU in interpreting EU data protection law remains authoritative. This is provided for by s.6 of the European Union (Withdrawal) Act 2018 which states that although a court or tribunal is not bound by any principles laid down, or any decisions made by the CJEU *on or after exit day* they are to have reference to retained case law (i.e. decisions made before Brexit Day) where the law has not been

modified.¹⁸ This means pre-Brexit case law is binding with reference to retained and unmodified EU law with exception of the Supreme Court which cannot be so bound.¹⁹ Further, by s.6(2) a court or tribunal may have regard to post-Brexit decisions of the CJEU or any other EU entity 'so far as it is relevant to any matter before the court or tribunal'. The CJEU will remain for many years a primary source of jurisprudence on UK GDPR until such time as UK courts build up a considerable body of domestic jurisprudence or until the framework of UK GDPR is substantially amended by the Data Protection and Digital Information Bill or some other domestic Act.

Finally, UK businesses will hope to trade with businesses and customers within the EU with the least possible friction. For this reason an adequacy decision of the Commission is valuable (see further Chapter 24). The UK is currently in receipt of an adequacy decision made on 28 June 2021.²⁰ This decision currently remains in effect to 27 June 2025 unless withdrawn. This is a disincentive to making wholesale changes to UK GDPR. At time of writing the future of UK GDPR is slightly unclear. The Data Protection and Digital Information Bill, designed to modernize UK GDPR and make it more 'business friendly' was removed from the business of the House on 5 September 2022 the day it was supposed to proceed to a second reading. The Culture Secretary then indicated to the Conservative Party Conference in October 2022 that the government intended to 'replace GDPR with our own business and consumer-friendly, British data protection system. Our plan will protect consumer privacy and keep their data safe, whilst retaining our data adequacy so businesses can trade freely.'²¹ To develop a more liberal data protection regime and yet to retain adequacy will be complex. It is assumed this means that the Data Protection and Digital Information Bill may now be withdrawn to be replaced with a new proposal in early 2023.²²

p. 598 Considering all of this I have had to carefully consider how to review and update chapters 22–25 for this new edition. I have taken the decision not to refer to the provisions ↵ of the Data Protection and Digital Information Bill on the assumption that it will be abandoned in its current form long before this edition is published. I have decided to continue to refer to the provisions of EU GDPR as they have been implanted into UK GDPR and will continue to refer to CJEU case law prior to Brexit Day as authoritative. Relevant CJEU case law made post-Brexit Day will be referred to as influential on UK GDPR. Where relevant the discussion will be framed essentially as UK GDPR within EU GDPR and where references are made to EU GDPR the reader may assume they are equally applicable to UK GDPR. Where there are specific differences between UK GDPR and EU GDPR these will be discussed in the text.

22.1.3 The territorial scope of EU GDPR and UK GDPR

The first substantial change introduced by GDPR is the territorial scope of the Regulation. The 1995 Directive had a narrow scope. Taking its lead from the 1981 Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data,²³ the Directive applied only where the data controller or processor was established within the territory of an EU Member State.²⁴ In essence, this meant that they were either established in a Member State or had localized equipment or personnel for the processing of data in that Member State. This made sense in the 1990s as processing normally was a localized practice with established data centres or customer call centres. As technology advanced and as services became more generalized,

offered over cloud servers, or simply were a result of online activity, this concept of localization became dated. As a result, the CJEU over time became more inventive as to what qualified as establishment under the Directive.

In *Weltimmo*, the court used Recital 19 to create a ‘flexible’ approach to establishment.²⁵ The Recital explains that ‘establishment on the territory of a Member State implies the effective and real exercise of activity through stable arrangements and that the legal form of such an establishment, whether simply branch or a subsidiary with a legal personality, is not the determining factor in this respect.’ The court suggested this meant that this:

results in a flexible definition of the concept of ‘establishment’, which departs from a formalistic approach whereby undertakings are established solely in the place where they are registered. Accordingly, in order to establish whether a company, the data controller, has an establishment, both the degree of stability of the arrangements and the effective exercise of activities must be interpreted in the light of the specific nature of the economic activities and the provision of services concerned. This is particularly true for undertakings offering services exclusively over the Internet.²⁶

To determine whether a business operating an online presence would be established in a state the court set out a three-stage test:

1. Is there an exercise of real and effective activity—even a minimal one?
2. Is the activity sufficient to constitute a stable arrangement?
3. Is personal data processed in the context of the activity?

p. 599 ↪ Applying this the court held that a Slovakian registered company which operated a property dealing website advertising Hungarian properties in Hungary was established in Hungary and was subject to supervision by the Hungarian data protection authority.

A similar expansive approach was taken in the *Google Spain* case.²⁷ This case, which will be discussed in much greater detail at 23.2, dealt with an application by a Spanish citizen to have data about him removed from Google search returns (the so-called ‘right to be forgotten’). It was clear that Google’s Spanish subsidiary, Google Spain, was established in Spain and was subject to supervision by the Spanish data protection agency. The issue was whether the authority of the agency could extend to Google Inc. which had no direct establishment in Spain, but which operated search facilities there. In this regard, the case is like the *Yahoo! France* and *Google v Equustek* cases discussed in chapter 5.

The court found that the activities of Google Inc., as a search engine operator, and those of its establishment, were ‘inextricably linked’ as Google’s search engine service is closely related to the activity of selling advertising space via its Spanish subsidiary.²⁸ The court noted that ‘the Spanish Government and the Commission have pointed out, Article 4(1)(a) of Directive 95/46 does not require the processing of personal data in question to be carried out “by” the establishment concerned itself, but only that it be carried out “in the context of the activities” of the establishment’.²⁹ Applying the principle that ‘the objective of the Directive

of ensuring effective and complete protection of the fundamental rights and freedoms of natural persons, and in particular their right to privacy, with respect to the processing of personal data, those words cannot be interpreted restrictively',³⁰ they found that:

the processing of personal data for the purposes of the service of a search engine such as Google Search, which is operated by an undertaking that has its seat in a third State but has an establishment in a Member State, is carried out 'in the context of the activities' of that establishment if the latter is intended to promote and sell, in that Member State, advertising space offered by the search engine which serves to make the service offered by that engine profitable.³¹

The *Weltimmo* and *Google Spain* decisions clearly illustrated how the world had changed since 1995. Data controllers and processors were now more likely to be established outside of the state seeking to regulate them and in many cases are likely to be established outside of the EU entirely. As a result, GDPR started from the flexible approach outlined in *Weltimmo* and *Google Spain* and substantially widened the territorial scope of EU data protection law. ↵

p. 600

Highlight GDPR Article 3

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.
2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to: the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or the monitoring of their behaviour as far as their behaviour takes place within the Union.
3. This Regulation applies to the processing of personal data by a controller not established in the Union, but in a place where Member State law applies by virtue of public international law.

This is an extremely wide scope, and to assist in understanding and applying it the European Data Protection Board issues guidance in November 2018.³² The Guidelines are split into four sections: (1) the application of the 'establishment' criterion in Article 3(1); (2) the 'targeting' criterion in Article 3(2); (3) the application of the GDPR to processing by a non-EU established controller in a place where Member State law applies by virtue of public international law under Article 3(3); and (4) the requirement for a representative to be appointed by a non-EU established controller or processor. We will look only at the first three of these starting with the establishment criteria.

The EDPB recommends a threefold approach in determining whether the processing of personal data falls within the scope of the GDPR pursuant to Article 3(1): (1) Does the controller or processor have an 'establishment' in the EU? (2) Does the controller or processor process personal data 'in the context of the activities of' the establishment? And (3) where does the processing take place? To address the first of these we can begin with Recital 22 'establishment implies the effective and real exercise of activities through stable arrangements. The legal form of such arrangements, whether through a branch or a subsidiary with a legal personality, is not the determining factor in that respect' and the decisions in *Weltimmo* and *Google Spain* which suggest establishment extends to any real and effective activity exercised by a controller or processor through stable arrangements.³³ The EDPB gives an example.

Example Establishment

A car manufacturing company with headquarters in the US has a fully-owned branch office located in Brussels overseeing all its operations in Europe, including marketing and advertisement. The Belgian branch can be considered to be a stable arrangement, which exercises real and effective activities in light of the nature of the economic activity carried out by the car manufacturing company. As such, the Belgian branch could therefore be considered as an establishment in the Union, within the meaning of the GDPR.

p. 601

Once it is concluded that a controller or processor is established in the EU, the analysis should follow on to determine whether the processing 'is carried out in the context of the activities of the establishment'. The EDPB states that two factors may help to determine whether the processing is being carried out by a controller or processor in the context of its establishment in the Union. The first is the relationship between the non-EU based controller or processor and the local EU establishment, and whether there is an inextricable link between the activities of the EU establishment and the processing carried out by a non-EU controller or processor. If so, the GDPR will apply. The second is any revenue raised by an establishment in the EU which may be considered as inextricably linked to the processing of personal data taking place outside the EU which may be sufficient to result in the application of EU law to such processing. Another example assists.³⁴

Example Activities

An e-commerce website is operated by a company based in China. The personal data processing activities of the company are exclusively carried out in China. The Chinese company has established a European office in Berlin in order to lead and implement commercial prospection and marketing campaigns towards EU markets. In this case, it can be considered that the activities of the European office in Berlin are inextricably linked to the processing of personal data carried out by the Chinese e-commerce website, insofar as the commercial prospection and marketing campaign towards EU

markets notably serve to make the service offered by the e-commerce website profitable. The processing of personal data by the Chinese company in relation to EU sales is indeed inextricably linked to the European Office in Berlin relating to commercial prospection and marketing campaign towards EU market. The processing of personal data by the Chinese website in connection with EU sales, can therefore be considered as carried out in the context of the activities of the Berlin office, and subject to the GDPR.

Finally, for Art.3(1) there is the question of where the processing takes place. The place of actual processing is irrelevant in determining whether the processing falls within the scope of the GDPR. It is the presence, through an establishment, of a controller or processor in the EU and the fact that processing takes place in the context of the activities of that establishment that triggers the application of the GDPR.³⁵ A final example

p. 602 assists. ↵

Example Place of Processing

A pharmaceutical company with headquarters in Stockholm has located all its personal data processing activities with regards to its clinical trial data in its branch based in Singapore. In this case, while the processing activities are taking place in Singapore, that processing is carried out in the context of the activities of the pharmaceutical company in Stockholm i.e. of a data controller established in the Union. The provisions of the GDPR therefore apply to such processing, as per Art. 3(1).

The second provision allowing the extended territorial scope of GDPR are the targeting principles of Art.3(2). The EDPB confirms that a controller or processor not established in the EU may be subject to the GDPR in relation to some of its processing activities, but not in relation to other processing activities. In assessing the application of the 'targeting' criterion, the EDPB recommends a multipart approach. The first is to determine whether the processing relates to the personal data of data subjects located within the EU. It is only data relating to data subjects located within the EU that is in scope for Art.3(2). The EDPB considers that the application of the targeting criterion is not limited by the nationality or place of residence of the data subject —rather the location of the data subject in the territory of the EU 'at the moment when the relevant trigger activity takes place' is the determining factor. The element of targeting individuals in the EU must be present to trigger the application of the GDPR to the non-established controller.³⁶ Two examples assist.

Example Targeting

Example A

A start-up established in the USA, without any business presence or establishment in the EU, provides a city-mapping application for tourists. The application processes personal data concerning the location of customers using the app (the data subjects) once they start using the application in the city they visit, to offer targeted advertisement for places to visits, restaurant, bars, and hotels. The application is available for tourists while they visit New York, San Francisco, Toronto, Paris, and Rome. The start-up is specifically targeting individuals in the Union (namely in Paris and Rome) through offering its services to them when they are in the Union and falls within the scope of the GDPR as per Art.3(2).

Example B

A US citizen is travelling through Europe during his holidays. While in Europe, he downloads and uses a news app that is offered by a US company. The app is exclusively directed at the US market, evident by the app terms of use and the indication of US Dollar as the sole currency available for payment. The collection of the US tourist's personal data via the app by the US company is not subject to the GDPR.

p. 603 ↵ What is different between these two examples is the targeting 'trigger'. This is the offering of goods or services to EU data subjects. This includes the offering of information society services and is not dependent on whether payment is made in exchange for the goods or services provided but whether the offer of goods or services is directed at a person in the Union.³⁷ The EDPB clarify that 'a trader could be considered to be "directing" its activity to the Member State of the consumer's domicile, where the trader has manifested its intention to establish commercial relations with such consumers'.³⁸

The second activity which might constitute targeting is monitoring of data subjects' behaviour. This can trigger Art.3(2) insofar as their behaviour takes place within the EU. Vitally for operators of websites: 'The EDPB does not consider that any online collection or analysis of personal data of individuals in the EU would automatically count as "monitoring". It will be necessary to consider the controller's purpose for processing the data and, in particular, any subsequent behavioural analysis or profiling techniques involving that data.'³⁹ They note the wording of Recital 24, which indicates that to determine whether processing involves monitoring of a data subject behaviour, the tracking of natural persons on the internet, including the potential subsequent use of profiling techniques, is a key consideration. They then helpfully provide a list of the type of activities which might bring the data controller within Art.3(2):

- Behavioural advertising
- Geo-localization activities, in particular for marketing purposes
- Online tracking through the use of cookies or other tracking techniques such as fingerprinting
- Personalized diet and health analytics services online

- CCTV
- Market surveys and other behavioural studies based on individual profiles, and
- Monitoring or regular reporting on an individual's health status.⁴⁰

Another example once again helps with clarification.

Example Monitoring

A retail consultancy company established in the US provides advice on retail layout to a shopping centre in France, based on an analysis of customers' movements throughout the centre collected through Wi-Fi tracking. The analysis of a customers' movements within the centre through Wi-Fi tracking will amount to the monitoring of individuals' behaviour. In this case, the data subjects' behaviour takes place in the Union since the shopping centre is in France. The consultancy company, as a data controller, is therefore subject to the GDPR in respect of the processing of this data for this purpose as per Art.3(2)(b). In accordance with Art.27, the data controller will have to designate a representative in the Union.

p. 604 ↩ Finally, we have guidance on the application of the GDPR to processing by a non-EU established controller under Art.3(3) this the EDPB is happy to confirm is a narrow and specialized provision applying to personal data processing carried out by EU Member States' embassies and consulates located outside the EU.⁴¹

At this point we turn our attention to UK GDPR which is slightly different in wording to Art.3 of EU GDPR. The most obvious and expected difference is that whereas EU GDPR refers to 'the Union' and 'processing taking place within the Union', UK GDPR replaces such references with 'the United Kingdom'. This makes sense and means that all the foregoing analysis should be transferrable to UK GDPR by replacing establishment in or targeting of the EU with establishment in or targeting of the UK. UK GDPR also has an additional Art.3(2A) which was added by The Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019.⁴² This sets out some targeting exemptions. However, these broadly map onto pre-existing exemptions found in Art.2(2) of EU GDPR. The only substantive distinction is that it exempts from targeting under Art.3(2) data covered by Art.2(1A) of UK GDPR which is manual unstructured personal data held by an FOI public authority. This makes no real difference as FOI public authorities are all UK-based and therefore are established under Art.3(1) and as a result Art.3(2) need not be engaged.

The first case to consider Art.3 in detail is an English case decided post-Brexit but applying EU GDPR as the claim was brought before 31 December 2020, when the post-Brexit transition period came to an end and EU GDPR ceased to apply. This may seem to be a case in a legal cul-de-sac as it is a decision on a piece of legislation no longer in force in the place where the decision was made and the decision of the court is of no authority in the place where the law remains in force. However, as Warby LJ explains 'Our decision is not of

merely historic interest. That is for at least three related reasons: the claim extends to processing after 31 December 2020; some of the continued processing complained of has allegedly taken place in the EU; and the content of the GDPR has been adopted, with appropriate amendments, as part of English law in the form of “the UK GDPR”.⁴³ The case is *Soriano v Forensic News LLC* and came about when the defendants published a series of articles and social media posts making a number of unflattering allegations about Mr Soriano. Mr Soriano raised a defamation claim but also claims in data protection and malicious falsehood. The defendants are a US-based organization and Mr Soriano sought permission to serve a claim outside of the jurisdiction. In deciding whether to grant permission, the Court of Appeal had to determine whether his allegations that the GDPR applied to the processing carried out by the defendants had a real prospect of success which meant analysing Art.3.

The court began by looking at Art.3(1). Applying previous decisions in relation to the Data Protection Directive (*Weltimmo*, *Google Spain*, and *Amazon*⁴⁴) and following the advice of the EDPB, the court focused on the subscription platform used by the defendant. This was a Patreon account which took payments in dollars, sterling, and euros. Mr Soriano claimed that as the website solicited donations in sterling and in euros and included a store which accepted shipping addresses in the UK these were ↵ stable arrangements, inasmuch as they remained in place until cancelled.⁴⁵ Warby LJ agreed, finding that ‘the authorities set a low bar, and all the claimant has to do at this stage is to persuade the court that it is not fanciful to think that his case crosses that low bar’.⁴⁶ That low bar was cleared because in the words of Warby LJ while:

p. 605

Recital 23 suggests that a critical consideration here is whether the data controller or processor ‘envisages offering services to data subjects in one or more Member States in the Union’ the defendants did more than merely making their journalism accessible over the world wide web. They intended to make their output available in the UK and EU, and succeeded in attracting a more than minimal readership. In due course they expressly solicited subscriptions from within the UK and EU, via the Patreon platform. They succeeded in securing three subscriptions in sterling and three in euros. This may be ‘minimal’ activity but nothing more is required, according to the authorities.⁴⁷

The question was were these arrangements ‘stable’? At first instance Jay J had felt it was not as the subscriptions could be cancelled at any time but Warby LJ disagreed finding that ‘the answer is not necessarily dependent on what subscribers can do in principle, as opposed to what happens in fact’ and that ‘subscription arrangements of this kind should be viewed as stable in nature’.⁴⁸ On this basis establishment was found and Mr Soriano given permission to serve out of jurisdiction.

The court might have left the analysis there but fortunately for us Warby LJ also examined Arts.3(2)(a) and (b). Starting with Art.3(2)(a) and targeting on the basis of an offering of goods and services. Here there was some confusion between the court and the parties. The court wanted to suggest that ‘the Regulation should apply to processing of an individual’s personal data that has some relationship with offering goods or services *to that individual*’.⁴⁹ In other words, Warby LJ was suggesting that an ordinary reading of the words of Article 3(2)(a) indicate that it should only apply to processing of an individual’s personal data where the processing activities are related to offering goods or services *to that specific individual*. Mr Soriano was not one of the individuals to whom the services were offered. However, none of the parties had argued for that interpretation of Article 3(2)(a). They had both argued ‘on the footing that Article 3(2)(a) applies to the

processing of personal data of data subjects who are in the Union whether or not they are the same individuals as those to whom the goods or services are offered, providing the two activities are “related to” one another’.⁵⁰

p. 606 Applying this analysis Warby LJ seemed to get himself momentarily tied up in knots. The problem was that the parties had conflated the offering of ‘goods’ on the website with targeting under Art.3(2)(a) but the activity complained of was the journalistic activity not the sale of goods. Warby LJ began by saying that ‘on no reasonable view is the journalistic processing of which the claimant complains “related to” the offer of goods to data subjects within the Union’ and that although they ‘no doubt have a commercial relationship with one another, this approach to the interpretation of Article 3(2)(a) would give it a breadth and scope beyond what is indicated by the words used and the Guidelines.’⁵¹ However, as soon as he has dismissed this as overbroad he then found that ‘it is arguable that the journalistic processing complained of is “related to” an offer made by the defendants to data subjects in the Union to provide them with services in the form of journalistic output.’⁵² The Art.3(2)(a) targeting provision was, in Warby LJ’s view, made out in regard to the journalistic offering but not the offering of goods. This it is to be remembered is decided against the court’s own reading of the provision because of the consensus between the parties on this point.

Finally, the court examined Art.3(2)(b). It rejected the argument that the publication of articles containing the claimant’s personal data is itself a form of ‘monitoring’ within Article 3(2)(b) finding such an argument to be artificial.⁵³ However, it did find that there was ‘a more compelling case under Article 3(2) that when someone uses the internet to collect information about the behaviour in the EU of an individual who is in the EU, and then assembles, analyses and orders that information for the purposes of writing and publishing an article about that behaviour in (among other places) the EU they are thereby engaging in “the monitoring of the data subject’s behaviour within the Union” within Article 3(2)(b).’⁵⁴ As Warby LJ notes ‘the publication of personal data clearly is a form of “processing”. The preparatory activities are plainly integral to that processing. It follows that the GDPR applies in such a case on the footing that publication amounts to a “processing of personal data of [the data subject]” which is “related to” the monitoring.’⁵⁵

This outcome raised concerns about the territorial scope of both EU GDPR and UK GDPR and there has been critique of the approach taken by Warby LJ. Ian De Freitas and Athalie Matthews of Farrer & Co note that ‘the territorial scope of the GDPR might well be wider than previously thought. The “minimal” connection required to satisfy Article 3(1) would be satisfied by a website with just six European subscribers but a demonstrable intent to reach European readers. For Article 3(2), “offering goods and services” and “monitoring” can include researching and publishing journalistic articles about a person based in Europe and publishing them within Europe’ a decision which they note ‘threatens to cast the GDPR shadow over organisations and businesses based in third countries’.⁵⁶ Meanwhile, Dechert LLP noted that:

it is important to note that this case relates to permission to serve a claim outside the UK. It was sufficient for the claimant to show that there was a more than fanciful prospect that the GDPR was broad enough to cover the allegedly infringing activity. The court therefore did not need to make any definitive findings on the territorial scope of the GDPR.⁵⁷

As they note ‘assuming that the case progresses rather than settles, the judgment on these issues following trial will be one to look out for.’⁵⁸

p. 607 **22.2 Data and data processing**

Both versions of GDPR begin by defining its material scope. Article 1(1) sets out that both apply to ‘natural persons with regard to the processing of personal data and rules relating to the free movement of personal data’. Neither applies to legal personalities such as corporations, clubs, or societies.⁵⁹ Nor do they apply once the natural person dies. This is expanded upon by Art.2, which sets out the material scope of the Regulation.

Highlight Material Scope (Article 2) UK GDPR

1. This Regulation applies to the automated or structured processing of personal data, including –
 - (a) processing in the course of an activity which, immediately before IP completion day,⁶⁰ fell outside the scope of EU law, and
 - (b) processing in the course of an activity which, immediately before IP completion day, fell within the scope of Chapter 2 of Title 5 of the Treaty on European Union (common foreign and security policy activities).
- 1A. This Regulation also applies to the manual unstructured processing of personal data held by an FOI public authority.
2. This Regulation does not apply to–
 - (a) the processing of personal data by an individual in the course of a purely personal or household activity;
 - (b) the processing of personal data by a competent authority for any of the law enforcement purposes (see Part 3 of the 2018 Act);
 - (c) the processing of personal data to which Part 4 of the 2018 Act (intelligence services processing) applies.
5. (a) ‘the automated or structured processing of personal data’ means–
 - (i) the processing of personal data wholly or partly by automated means, and
 - (ii) the processing otherwise than by automated means of personal data which forms part of a filing system or is intended to form part of a filing system;
- (b) ‘the manual unstructured processing of personal data’ means the processing of personal data which is not the automated or structured processing of personal data;

There are a few things to be taken away from this. The Regulation only applies to personal data. This is defined by Art.4(1) as:

p. 608

any information relating to an identified or identifiable natural person (data subject); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier ↵ or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.

What at first glance appears to be straightforward is actually quite complicated. While personal data can clearly include personal names and addresses as well as online identifiers such as IP addresses and mobile device IDs (including telephone numbers) and even pseudonymous data,⁶¹ it is not true that under every circumstance these forms of data will *always* be personal data. The Information Commissioner's Office explains this by reference to a person's name:

A name is perhaps the most common means of identifying someone. However, whether any potential identifier identifies an individual depends on the context.⁶²

As they explain 'If, by looking solely at the information you are processing you can distinguish an individual from other individuals, that individual will be identified (or identifiable).' If we take a common name like David Smith (which apparently is the most common name in the UK) I can write here about David Smith without engaging data protection law because although this *can* be personal data unless a specific David Smith is identifiable from this data, it is not 'information relating to an identified or identifiable natural person'. With apparently over 6,000 potential David Smith's in the UK who might be the one I am writing about absent additional details to narrow the pool to a specific David Smith this is not yet, personal data.

The ICO go on to explain that a name is though only one possible identifying characteristic: 'You don't have to know someone's name for them to be directly identifiable, a combination of other identifiers may be sufficient to identify the individual.'⁶³ Essentially to be personal data you must be able to identify *a* living individual from that information, either on its own or in combination with other information you possess or which you may be able to possess. The information may be information which is true or false. If you were to hold personal data about me which allowed you to identify me (perhaps by reference to my current employer and job title) but which was inaccurate (such as you have recorded my address incorrectly) this is still personal data. This is important for as we shall see the data subject has a right to correct errors in any data held or processed on them.

p. 609

The definition of personal data is 'any information *relating to* an identified or identifiable natural person'. That is a key phrase—when does data 'relate to' an individual? This question has been revisited over the years by the courts. In the controversial case of *Durant v Financial Services Authority*⁶⁴ the Court of Appeal examined the question of when data 'related to' the applicant. The case is discussed in greater detail at 23.1.1 but for now it is important to note that when asked whether files held by the FSA relating ↵ to Mr Durant's complaint against Barclays Bank were personal data Buxton LJ recorded that 'on the ordinary meaning of the expression Mr Durant's letters of complaint to the FSA, and the FSA's investigation of that complaint, did not relate to Mr Durant, but to his complaint'. He explained that 'the Data Protection Act would only be engaged if, in the

course of investigating the complaint, the FSA expressed an opinion about Mr. Durant personally, as opposed to an opinion about his complaint'.⁶⁵ This decision was criticized at the time,⁶⁶ and is no longer considered good law.

In 2007 the Art.29 Working Party clarified that 'in general terms, information can be considered to "relate" to an individual when it is about that individual'.⁶⁷ They go on to give useful examples of when data 'relates to' an individual. First, they demonstrate the direct link: 'in many situations, this relationship can be easily established. For instance, the data registered in one's individual file in the personnel office are clearly "related to" the person's situation as an employee. So are the data on the results of a patient's medical test contained in his medical records, or the image of a person filmed on a video interview of that person.' Then there is the possibility of an indirect link; this is where for example information relates to an object which can be tied to an individual. The example they give is of a house price valuation. This seems not to be personal data but as the Working Party explain 'under certain circumstances such information should also be considered as personal data. Indeed, the house is the asset of an owner, which will hence be used to determine the extent of this person's obligation to pay some taxes, for instance. In this context, it will be indisputable that such information should be considered as personal data.'⁶⁸

They go on to identify three further ways in which data may indirectly relate to the individual. The first is where the *content* of the information relates to the individual. This is where information is clearly 'about' a person. As the Working Party explain:

information 'relates' to a person when it is 'about' that person, and this has to be assessed in the light of all circumstances surrounding the case. For example, the results of medical analysis clearly relate to the patient, or the information contained in a company's folder under the name of a certain client clearly relates to him. Or the information contained in a RFID tag or a bar code incorporated in an identity document of a certain individual relates to that person, as in passports with a RFID chip.⁶⁹

p. 610 Second, there is data which *purpose* it is to 'to evaluate, treat in a certain way or influence the status or behaviour of an individual'. An example would be a call log for a telephone. Although the log may not directly contain personal data, the log would allow a company to monitor the employee who uses that phone and in addition can provide information on who called, or was called, and can be used to determine when the employee is in or out of the office. Finally, there is data which when processed produces a *result* 'likely to have an impact on a certain person's rights and interests, taking into account all the circumstances surrounding the precise case'. The Working Party give an example of location data held by a taxi company for the purpose of optimizing the service. As they point out, while the location of cars may not immediately be personal data, 'the system does allow monitoring the performance of taxi drivers and checking whether they respect speed limits, seek appropriate itineraries, are at the steering wheel or are resting outside, etc. It can therefore have a considerable impact on these individuals, and as such the data may be considered to also relate to natural persons.'⁷⁰

These clarifications suggested that *Durant* was wrong in finding that the files regarding Mr Durant's claim were information about his complaint (not personal data) rather than information about him (personal data). This position was revisited domestically in *Edem v IC & Financial Services Authority*.⁷¹ Here the Court of Appeal considered the application of the test set forth in *Durant* and concluded that the meaning of personal data should be interpreted in accordance with the Information Commissioner's technical guidance note,⁷² rather than the more restrictive interpretation of *Durant*. In particular, the court confirmed that the more restrictive test in *Durant* should apply only in limited circumstances, namely where the information in question is not obviously about an individual, or clearly linked to them.⁷³

Currently, the leading case is *Nowak v Data Protection Commissioner*, a CJEU decision following a reference from Ireland.⁷⁴ The case arose as a result of the Institute of Chartered Accountants of Ireland (CAI) refusing a request by an accountancy student, Peter Nowak, for a copy of his failed exam script. The CAI concluded that the exam script did not contain personal data and therefore did not fall within the scope of data protection law. Nowak submitted a formal complaint to the Irish Data Protection Commissioner, who also determined that the exam script was not personal data. Nowak appealed eventually to the Supreme Court of Ireland. At the Supreme Court, the Data Protection Commissioner relied on the opinion of the Advocate General in the case of *YS and Others* that: 'only information relating to facts about an individual can be personal data. Except for the fact that it exists, a legal analysis is not such a fact. Thus, for example, a person's address is personal data but an analysis of his domicile for legal purposes is not.'⁷⁵ The Supreme Court referred a question to the CJEU as to whether the written answers provided by a candidate at an exam, and any examiner's comments with respect to those answers, constitute personal data.

p. 611 The CJEU held that written answers provided by a candidate and any comments made by the examiner with respect to those answers constitute information relating to that candidate and are therefore personal data. It found that 'the content of those answers reflects the extent of the candidate's knowledge and competence in a given field and, in some cases, his intellect, thought processes, and judgment. In the case of a handwritten script, the answers contain, in addition, information as to his handwriting.'⁷⁶ Further, 'the purpose of collecting those answers is to evaluate the candidate's professional abilities and his suitability to practice the profession concerned',⁷⁷ and 'the use of that information, one consequence of that use being the candidate's success or failure at the examination concerned, is liable to have an effect on his or her rights and interests, in that it may determine or influence, for example, the chance of entering the profession aspired to or of obtaining the post sought'.⁷⁸ As a result, the court held that both the exam answer, as well as the examiner's comments were 'by reason of content, purpose or effect, linked to that candidate [and this] is not called into question by the fact that those comments also constitute information relating to the examiner'.⁷⁹

There is one interesting wrinkle of the *Nowak* decision. The exam was anonymously marked. This meant that the exam paper was in terms of data protection law pseudonymous. The examiner never knew Mr Nowak's identity (and indeed could not know), only the CAI had both his candidate number and his name. This brings us finally to the identifiability criterion. You should remember that according to Art.3(1) of both EU GDPR and UK GDPR 'an identifiable natural person is one who can be identified, directly or indirectly'. Again, the Recitals offer assistance. Recital 26 tells us that:

to determine whether a natural person is identifiable, account should be taken of *all the means reasonably likely to be used*, such as singling out, either by the controller or by another person to identify the natural person directly or indirectly. To ascertain whether means are reasonably likely to be used to identify the natural person, account should be taken of all objective factors, such as the costs of and the amount of time required for identification, taking into consideration the available technology at the time of the processing and technological developments.

The fact that the CAI had possession of both the exam paper, with comments, and a means to identify Mr Nowak suggested he was identifiable. Fortunately, for the court it could refer to an earlier case, *Breyer*, which is actually very important for all Information Technology Law students.⁸⁰

Breyer concerned the question of whether an IP address could qualify as personal data. Mr Breyer's IP address was dynamically allocated (i.e. each time he connected to the network, his device is issued with a new IP address). Ordinarily, a dynamic IP address does not provide a website operator with sufficient information to directly identify an individual user, unless additional information is also available (e.g. the user logs into the website and provides information that enables the website operator to identify that user). The parties agreed that the IP address in question did not directly identify Mr Breyer. The question was whether Mr Breyer was indirectly identifiable, from his dynamic IP address in combination with other available information. The parties agreed that Mr Breyer could be indirectly identified by the combination of his IP address plus account data held by his ISP. The court had to determine whether the test for determining identifiability is (a) objective (i.e. the IP address is personal data in everybody's hands because the ISP can link it to Mr Breyer's real world identity, even if nobody else can legally do so); or (b) relative (i.e., the IP address is personal data in the ISP's hands, but would not be personal data in the hands of another party who had no lawful means of accessing the information held by the ISP). The court determined it was a question of relative identifiability:

a dynamic IP address registered by an online media services provider when a person accesses a website that the provider makes accessible to the public constitutes personal data within the meaning of that provision, in relation to that provider, where *the latter has the legal means which*

↪ *enable it to identify the data subject with additional data which the internet service provider has about that person.*⁸¹

p. 612

Applying *Breyer* the court in *Nowak* found that 'there is no requirement that all the information enabling the identification of the data subject must be in the hands of one person.'⁸² The fact that Mr Nowak could be identified rather easily meant the identifiability criterion was met.

22.2.1 Data subjects, data controllers, and processors

Both EU GDPR and UK GDPR define the personnel of the data protection environment by identifying three key actors. The first are data subjects, which are defined as 'an identified or identifiable natural person'.⁸³ The Regulation does not apply to legal personalities such as corporations, clubs or societies—as Recital 14 puts it: 'this Regulation does not cover the processing of personal data which concerns legal persons and in particular undertakings established as legal persons, including the name and the form of the legal person and the

contact details of the legal person.’ Of course the divide between natural and legal persons is not always as clear as the Regulation suggests. Often micro-undertakings will share a name with their owner (e.g. one of the most high-profile law firms in Scotland is Aamer Anwar & Co. named for its founder). Often micro-undertakings will operate from the private address of their owner which doubles as the address of the undertaking. It is quite common to combine personal data with data of legal persons. This requires courts to carefully unpack the legal personality from the natural one—when is the data about the company and when is it data about the person? Only the latter is protected by the GDPR. Where the data is shared: such as address data or phone numbers it will be treated as personal data where ‘it relates to a natural person’ (see above).

Second, data controllers are ‘the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data’. The data controller is the party primarily responsible for compliance with the Regulation. By Art.24(1) the controller is required to ‘implement appropriate technical and organizational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation’ and to ensure ‘those measures shall be reviewed and updated where necessary’. There may be joint controllers, defined in Art.26(1) as ‘two or more controllers [who] jointly determine the purposes and means of processing’. The controller (or controllers) has significant responsibilities to the data subject including that they comply with Chapter 3 of the Regulation where considerable rights are awarded to the data subject, including subject access rights, the rights to rectification and erasure of data, and the notification obligation.

p. 613 The role of data controller was given consideration by the CJEU in the *Facebook fan page* case.⁸⁴ The case involved a private educational company who offered services by means of a fan page hosted on Facebook. Administrators of fan pages can obtain anonymous statistical information on visitors to the fan pages via a function called ‘Page Insights’ ↵ which Facebook makes available to them free of charge under non-negotiable conditions of use. The information is collected by means of cookies, each containing a unique user code, which are active for two years and are stored by Facebook on the hard disk of the computer or on other media of visitors to fan pages. The user code, which can be matched with the connection data of users registered on Facebook, is collected and processed when the fan pages are opened. The data protection supervisor for Schleswig-Holstein (a federal state in Germany) ordered the operator of the fan page to deactivate the page or face a fine as neither it nor Facebook, had the permission of the visitors to the page to have the tracking cookie installed on their machine and to process their data connected to it. The operator of the page challenged this finding arguing that the processing of personal data by Facebook could not be attributed to it and that it had not commissioned Facebook to process data that it controlled or was able to influence. They argued that the data protection supervisor should have acted directly against Facebook instead of it.

The case was referred to the CJEU who noted that the ‘aim [of] Article 2(d) of the directive defines the concept of “controller” broadly as the natural or legal person, public authority, agency or any other body which alone or jointly with others determines the purposes and means of the processing of personal data.’⁸⁵ This ‘is to ensure, through a broad definition of the concept of “controller”, effective and complete protection of the persons concerned’.⁸⁶ Who were the controller, or controllers, in the instant case? As the court observed, Facebook were clearly a controller for they ‘primarily determine the purposes and means of processing the personal data of users of Facebook and persons visiting the fan pages hosted on Facebook’.⁸⁷ In addition, the

operator of the fan page was also a controller for while ‘the mere fact of making use of a social network such as Facebook does not make a Facebook user a controller jointly responsible for the processing of personal data by that network, it must be stated, on the other hand, that the administrator of a fan page hosted on Facebook, by creating such a page, gives Facebook the opportunity to place cookies on the computer or other device of a person visiting its fan page, whether or not that person has a Facebook account’⁸⁸ and ‘the creation of a fan page on Facebook involves the definition of parameters by the administrator, depending inter alia on the target audience and the objectives of managing and promoting its activities, which has an influence on the processing of personal data for the purpose of producing statistics based on visits to the fan page. Consequently, the administrator of a fan page hosted on Facebook contributes to the processing of the personal data of visitors to its page.’⁸⁹

Operators of fan pages are therefore data controllers; however, the court was at pains to point out that different data controllers may have different levels of responsibility, noting that:

the existence of joint responsibility does not necessarily imply equal responsibility of the various operators involved in the processing of personal data. On the contrary, those operators may be involved at different stages of that processing of personal data and to different degrees, so that the level of responsibility of each of them must be assessed with regard to all the relevant circumstances of the particular case.⁹⁰

p. 614 ↵ Our third actor is data processors. These are ‘a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.’⁹¹ These are the agents of the data controller who carry out the day-to-day storage and processing of the data. An example would be the Tesco Clubcard scheme. Although the data controller would be Tesco plc, the operation of the scheme is not managed by Tesco but by a private company Dunnhumby Ltd.⁹² In this scenario Dunnhumby is the data processor to Tesco’s data controller. Processors, like controllers, have specific responsibilities under both EU and UK GDPR including that they ‘provide sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject’⁹³ and that they shall not sub-contract any processing without specific authorization.⁹⁴ As data processing is often outsourced to specialist companies, the data controller/ data processor distinction allows EU and UK GDPR to control both aspects of data management and processing.

22.2.2 Data processing and the data protection principles

The heart of the Regulation is the data controller/data processor relationship and their responsibilities to the data subject. These responsibilities are captured in the Data Protection Principles. By Art.5(2) ‘the controller shall be responsible for, and be able to demonstrate compliance with the principles’, found in Art.5(1).

Highlight The Data Protection Principles

Personal data shall be:

- (a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');
- (b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes ('purpose limitation');
- (c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');
- (d) accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay ('accuracy');
- (e)  kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject ('storage limitation');
- (f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').

p. 615

Although all the principles are of equal weight in many ways the key principle is the First Principle. This is the general principle that data processing shall be carried out in a lawful, fair, and transparent manner. This is an extremely vague term, which although supported by conditions for the fair processing of data has caused problems for courts in the UK and further afield.

The first issue is the rather vague term 'processing'. This is defined broadly by Art.4(2) of EU and UK GDPR (while the Data Protection Act 2018 essentially gives the same definition but in a slightly different order).

Highlight Processing Data (Art.4(2))

Processing means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.

This makes it clear that mere consultation of data is a data process as is the act of collecting and recording data. Creation of data, as well as its destruction, is a data process in of itself. Further, some data attracts additional protection: this is data known as 'special data' and it is defined in Art.9.

Highlight Special Data

Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation shall be prohibited.

p. 616 ↩ The common theme of special data is that it is data which may be used to discriminate against an individual. As such there is a special regime for such data both in the Regulation and the Data Protection Act.⁹⁵ The Act applies special conditions to the processing of data of this nature in Schs.8 and 10.

Not every action is processing in terms of the Regulation and Act. If we look to Art.2(5) UK GDPR we see that processing must be 'wholly or partly by automated means' or manual processing of data 'forming part of a filing system or intended to form part of a filing system'. This means the data must be stored or processed electronically or it should be stored or processed as part of a filing system which is 'any structured set of personal data which are accessible according to specific criteria, whether centralised, decentralised or dispersed on a functional or geographical basis'.⁹⁶

A simple act of recording or processing personal data not as part of an organized record, such as noting down on the back of an envelope the registration number of a vehicle parked outside your house or asking your friend if she knows the name of another person at a party, is not covered by the Regulation and Act. More structured processing will though bring the data within scope, such as searching the DVLA database to find who owns the car in question or adding the name to your list of contacts on your smartphone. Even allowing for this qualification, in the modern digital environment the definition of processing is potentially a very expansive set which could cover anything from hard-core data mining of gathered personal data by

commercial organizations to individuals mentioning friends and family on personal web pages without permission or otherwise in accordance with the Regulation and Act. Is this really the intent of EU data protection law?

The leading case to date on the question of ‘processing’ is the Swedish case of *Bodil Lindqvist*.⁹⁷ Mrs Lindqvist, in addition to her day job as a maintenance worker, worked as a catechist in the parish of Alseda in Sweden. She took a data processing course to allow her to develop an online presence for her church. She then set up internet pages using her personal computer in order to allow parishioners preparing for their confirmation to obtain information they might need. At her request, the administrator of the Swedish Church’s website set up a link between those pages and that site.

The pages in question contained information about Mrs Lindqvist and 18 colleagues in the parish, sometimes including their full names and in other cases only their first names. Mrs Lindqvist also described, in a mildly humorous manner, the jobs held by her colleagues and their hobbies. In many cases family circumstances and telephone numbers and other matters were mentioned. She also stated that one colleague had injured her foot and was on half-time on medical grounds. It was established that Mrs Lindqvist had not informed her colleagues of the existence of those pages or obtained their consent, nor did she notify the Datainspektionen (Swedish supervisory authority for the protection of electronically transmitted data) of her activity. She removed the pages in question as soon as she became aware that they were not appreciated by some of her colleagues.

p. 617 ↪ Mrs Lindqvist was charged with a breach of the Swedish Data Protection Act on the grounds that she had: (a) processed personal data by automatic means without giving prior written notification to the Datainspektionen; (b) processed sensitive personal data (injured foot and half-time on medical grounds) without authorization; and (c) transferred processed personal data to a third country without authorization. Mrs Lindqvist accepted the facts of the case but challenged that her activities (placing material on a website) did not qualify as ‘processing’ data under the Data Protection Directive 1995 and thereby the relevant Swedish law. The Swedish Court of Appeal referred the case to the CJEU.

In a wide-ranging opinion the CJEU found that:

Highlight

- (1) The act of referring, on an internet page, to various persons and identifying them by name or other means constituted the processing of personal data.
- (2) The processing of personal data such as that described in answer to the first question was not covered by any of the exceptions given in the Directive.
- (3) Reference to the fact that a colleague had injured her foot and was on half-time on medical grounds constituted personal data concerning health within the meaning of [sensitive personal data].
- (4)

The provisions of the Directive did not, in themselves, bring about restrictions which conflicted with the right to freedom of expression. It was for the national courts responsible for applying implementing legislation to ensure a fair balance between the rights and interests in question.

This gives an extremely expansive interpretation of ‘processing’. The simplest act of placing information on a personal website qualifies.

22.2.3 The domestic purposes exception

To suggest that data protection law apply to every act of every individual in which data is processed in a manner covered by the *Lindqvist* decision would make data protection law oppressive and almost impossible to comply with. It suggests keeping an address book on a mobile phone or writing a list of gifts for friends could only be done in accordance with the data protection principles. This would be overbearing and overreaching so the Regulation carves out an exemption for domestic processing.⁹⁸

p. 618 The domestic purposes exemption is carried over from the Directive and the 1998 Act so we have some case law to clarify when the exemption applies and when it does not. ↩ The first case to look at this was *Lindqvist* itself. Mrs Lindqvist argued that her activities were carried out in a private capacity and that the web page onto which she loaded data was a private one. The court disagreed finding that:

the exception must be interpreted as relating only to activities which are carried out in the course of private or family life of individuals, which is clearly not the case with the processing of personal data consisting in publication on the internet so that those data are made accessible to an indefinite number of people.⁹⁹

The CJEU returned to this issue in the case of *Ryneš v Úřad pro ochranu osobních údajů*.¹⁰⁰ Mr Ryneš had installed a CCTV camera on the exterior of his house, which recorded movements not only on his private property, but also the public footpath outside. He said he installed the camera to protect his family and his property, as there had been previous vandalism to his property. After the installation of the CCTV, his house windows were broken once more. The CCTV footage was used to identify two individuals, one of whom questioned whether the use of the CCTV system was permissible under the Czech data protection law. Mr Ryneš argued that the domestic processing exception applied.

The Czech court referred this question to the CJEU, asking:

Can the operation of a camera system installed on a family home for the purposes of the protection of the property, health and life of the owners of the home be classified as the processing of personal data ‘by a natural person in the course of a purely personal or household activity’ within the meaning of Article 3(2) of Directive 95/46/EC, even though such a system monitors also a public space?¹⁰¹

The court first clarified that the capture of an identifiable image of a person on a CCTV system is personal data within the definition of the Directive.¹⁰² It then clarified that ‘surveillance in the form of a video recording of persons, as in the case before the referring court, which is stored on a continuous recording device—the hard disk drive—constitutes the automatic processing of personal data’.¹⁰³ This just left the question of whether Mr Ryneš was covered by the domestic processing exception. The court noted that the decision in *Google Spain SL and Google Inc. v AEPD*,¹⁰⁴ provided that ‘the protection of the fundamental right to private life guaranteed under Article 7 of the Charter of Fundamental Rights of the European Union (the Charter) requires that derogations and limitations in relation to the protection of personal data must apply only in so far as is strictly necessary’¹⁰⁵ before going on to find that the actions of Mr Ryneš did not qualify for the domestic purposes exemption. ↵

p. 619

Highlight The Domestic Purposes Exemption (Ryneš)

The processing of personal data comes within the exception provided for in the second indent of Article 3(2) of Directive 95/46 only where it is carried out in the purely personal or household setting of the person processing the data. Accordingly, so far as natural persons are concerned, correspondence and the keeping of address books constitute, in the light of Recital 12 to Directive 95/46, a ‘purely personal or household activity’ even if they incidentally concern or may concern the private life of other persons. To the extent that video surveillance such as that at issue in the main proceedings covers, even partially, a public space and is accordingly directed outwards from the private setting of the person processing the data in that manner, it cannot be regarded as an activity which is a purely ‘personal or household’ activity for the purposes of the second indent of Article 3(2) of Directive 95/46.¹⁰⁶

The court, as in *Lindqvist*, ultimately applied a strict interpretation of the domestic processing exemption. This is possibly because Art.3(2) said it only applied to ‘a purely personal or household activity’. One final thing to note is that the court found that the domestic court was correct not to fine Mr Ryneš as ‘the application of Directive 95/46 makes it possible, where appropriate, to take into account legitimate interests pursued by the controller, such as the protection of the property, health and life of his family and himself, as in the case in the main proceedings’.¹⁰⁷

It may be argued that *Lindqvist* and *Ryneš* are now less authoritative than they were. This is due to Recital 18 of GDPR (emphasis added):

This Regulation does not apply to the processing of personal data by a natural person in the course of a purely personal or household activity and thus with no connection to a professional or commercial activity. Personal or household activities could include correspondence and the holding of addresses, or social networking and online activity undertaken within the context of such activities. However, this Regulation applies to controllers or processors which provide the means for processing personal data for such personal or household activities.

GDPR in moving with the times has recognized that people spend large amounts of their lives online. It is unlikely that if a modern Mrs Lindqvist were to post to Facebook her sympathies for a friend who had broken a leg that the courts would find that to be outside the domestic purposes exemption. However, as Art.2(2)(c) of EU GDPR and Art.2(2)(a) of UK GDPR both retain the key term 'a purely personal or household activity' it means that both *Lindqvist* and *Ryneš* retain some authoritative status, despite this slight variation in scope given in Recital 18. This means that if she were to repeat her actions of placing the information (unnecessarily) on a web page the outcome would likely be the same as in her original case. This makes the interpretation of 'fairness' of paramount importance, as only when data is processed 'fairly and lawfully' is the first data protection principle met.

p. 620 22.2.4 Fairness and lawfulness

The leading UK case on fairness is *Johnson v Medical Defence Union Ltd.*¹⁰⁸ The claimant, Mr Johnson, was a consultant orthopaedic surgeon with over 20 years clinical experience. He was, from 1980, a member of the Medical Defence Union (MDU), a mutual society which provides advice and professional liability insurance to its members. He was reported as having 'never been the subject of a claim for alleged professional negligence'.¹⁰⁹ However, it was reported that 'over the years he [had] sought advice and assistance from the MDU in relation to professional questions and problems that concerned him, including complaints made against him. His contact with the MDU, and that from others about him, gave rise to the opening at least since 1991 of 17 MDU files.'¹¹⁰ As a result of a review of their files the MDU wrote to Mr Johnson in January 2002 informing him they would not renew his membership at the end of his current subscription. The letter gave no reasons. Mr Johnson sought the reasons, but none were provided. As a result of the MDU's actions Mr Johnson claims he suffered damage to his professional reputation and financial loss. He made a claim under s. 13 of the Data Protection Act 1998 seeking compensation for unfair processing of his personal data.

At an initial hearing Mr Johnson's claims were dismissed.¹¹¹ Rimer J found that:

The MDU's risk policy was formulated against the background of a contractual relationship between the MDU and its members under which the MDU had and has an absolute discretion to terminate a member's membership and in which it was in the interests of all members that it should have a sound risk assessment policy. There might be legitimate scope for disagreement between those competent to judge these things as to whether the MDU risk assessment policy was sound or otherwise, or as to whether it could be improved. But I have no reason to believe that it was arrived at other than after proper consideration and that it was regarded as other than the most appropriate policy for the needs of the MDU. The MDU could process his data in the circumstances in which it did perfectly fairly without Mr Johnson's input, and the evidence from the MDU witnesses satisfied me that his input would be unlikely to have made any difference to the assessment of his case: because, put shortly, the policy regards a member's input as essentially irrelevant.¹¹²

According to Rimer J, Mr Johnson's suggestion that he 'was entitled to have his data processed and case considered by reference to his own inexperienced assertions as to the risk assessment policy that the MDU should apply' should be rejected.¹¹³

Mr Johnson appealed claiming the MDU's policy was flawed. He argued two flaws led to his personal data being processed unfairly. The first was that the MDU's policy of assessing members according to number of incidents or complaints rather than according to their outcome meant he was penalized and, second, because of that policy, the Risk Assessment Review process used by the MDU did not allow any explanation by the member of the various incidents reported to it.

p. 621 ↩ The Court of Appeal dismissed Mr Johnson's claim. They held that the MDU's processing of his personal data for the purpose of conducting a risk assessment review was, in relation to all but two of the files in question, fair and lawful under the Act, and dismissed his claim for compensation. Arden LJ noted that 'Mr Johnson gave his consent to the processing of personal data for a number of purposes, including risk management. The directive requires consent to be unambiguous. However, in my judgment, Mr Johnson did not have to know the nature of the MDU's risk assessment policy to give a valid consent for this purpose.'¹¹⁴ She went on to note:

the judge [Rimer J] did not accept Mr Johnson's submission, either in relation to the lead files or the non-lead files, that the MDU had an obligation to consult Mr Johnson about the processing exercise or to invite his representations upon it. In my judgment the judge was right to hold that the fairness principle did not require this. As a general proposition a party to a contract cannot in my judgment use the fairness principle as a means of upsetting any contractually permitted use of information where, as here, processing was foreseeable. I see no basis for displacing this general proposition in this case.¹¹⁵

The unfair processing of the remaining two files was held not to have caused damage. The court paid regard to the fact that Mr Johnson had signed-up to the MDU's risk assessment policy and agreed to the processing of his personal data for this purpose and held that the review was carried out within the terms of this policy. In terms of compensation, the court held that even if Mr Johnson had shown there to be a breach of the Act, there is nothing within the Act that would give him the right to compensation for a general loss of reputation. The court noted that a defamation claim would be a more appropriate course of action; however, the court did note that had the MDU breached the Act in processing Mr Johnson's personal data, he would have been able to claim for losses and distress 'by reason of a data controller's contravention of the Data Protection Act'.¹¹⁶

What is apparent from the cases we have discussed is the complexity of processing in accordance with the regulatory provisions. Mrs Lindqvist appeared to be engaged in an innocent activity, which she no doubt felt was a private matter, likewise Mr Ryněš believed he was processing for a private purpose and for the protection of his property. Both, however, fell foul of the law as their actions went further than their domestic purposes and had potential to impact on the data privacy of others. By comparison the Medical Defence Union was involved in high-level data processing with the potential to adversely affect the professional career of Mr Johnson and others that were subject to its risk assessment review. Ultimately though we know that Mrs Lindqvist's actions were in breach of the Swedish Data Protection law (and the Directive) while Mr Ryněš' actions were similarly in breach of Czech Data Protection law (and the Directive), while the actions of the Medical Defence Union were ultimately fair and lawful. How can a data controller process data with confidence given the complexity of the first data protection principle?

p. 622 22.3 Conditions for the processing of personal data

To assist data controllers in fulfilling the First Principle, Art.6(1) lists conditions in which the principle is met.

Highlight Lawfulness of Processing

Processing shall be lawful only if and to the extent that at least one of the following applies:

- a. the data subject has given consent to the processing of his or her personal data for one or more specific purposes;
- b. processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c. processing is necessary for compliance with a legal obligation to which the controller is subject;
- d. processing is necessary in order to protect the vital interests of the data subject or of another natural person;
- e. processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f. processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

In cases of special data Art.9(2) is applied. This states that the processing of such data should only take place on one or more of the following occasions.

Highlight Processing of Special Categories of Personal Data

- a. the data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where domestic law provides that the prohibition referred to in paragraph 1 may not be lifted by the data subject;
- b. processing is necessary for the purposes of carrying out the obligations and exercising specific rights of the controller or of the data subject in the field of employment and social security and social protection law in so far as it is authorized by domestic law or a collective agreement pursuant to domestic law providing for appropriate safeguards for the fundamental rights and the interests of the data subject;

p. 623

- c. processing is necessary to protect the vital interests of the data subject or of another natural person where the data subject is physically or legally incapable of giving consent;
- d. processing is carried out in the course of its legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that the processing relates solely to the members or to former members of the body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects;
- e. processing relates to personal data which are manifestly made public by the data subject;
- f. processing is necessary for the establishment, exercise or defence of legal claims or whenever courts are acting in their judicial capacity;
- g. processing is necessary for reasons of substantial public interest, on the basis of domestic law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject domestic law;
- h. processing is necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services on the basis of domestic law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3;
- i. processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices, on the basis of domestic law which provides for suitable and specific measures to safeguard the rights and freedoms of the data subject, in particular professional secrecy domestic law;
- j. processing is necessary for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) (as supplemented by section 19 of the 2018 Act) based on domestic law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject.

22.3.1 Consent

Most commonly data is processed according to the first condition: That is ‘the data subject has given consent to the processing of his or her personal data for one or more specific purposes’ or for special data, ‘the data subject has given *explicit* consent to the processing of those personal data for one or more specified purposes.’ What in practice does this mean?

p. 624 The starting point is Art.4(11) which defines consent as ‘any freely given, specific, informed and unambiguous indication of the data subject’s wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her’. Assistance is found in Art.7 ‘conditions for consent’. This tells us that ‘where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data’—the burden of proof for consent-based processing rests with the data controller. This, in part, is why when the GDPR came into force on 25 May 2018 you ↵ were faced with a flurry of requests to re-affirm your consent to be on any number of mailing lists and to allow web pages to install cookies and similar. Any organization that did not have a clear record of your consent was not compliant with GDPR if they processed data based upon that consent. What form must that consent take? As with Art.3, the EDPB has issued specific guidance.¹¹⁷

The guidance begins by taking the conditions of Art.4(11) and analysing each in turn so consent must be (1) freely given; (2) specific; (3) informed; and (4) unambiguous. Starting with freely given the guidance notes that ‘the GDPR prescribes that if the data subject has no real choice, feels compelled to consent or will endure negative consequences if they do not consent, then consent will not be valid. If consent is bundled up as a negotiable part of terms and conditions it is presumed not to have been freely given. Accordingly, consent will not be considered free if the data subject is unable to refuse or withdraw his or her consent without detriment.’¹¹⁸ Consent cannot be coerced or compelled. Further, ‘a service provider cannot prevent data subjects from accessing a service on the basis that they do not consent’.¹¹⁹ This means that access to a service cannot be conditional to the user’s consent to the processing of their personal data. Additionally, ‘access to services and functionalities must not be made conditional on the consent of a user to the storing of information, already stored, or gaining of access to information in the terminal equipment of a user’.¹²⁰ This is designed to prevent the use of so-called cookie walls—as the EDPB illustrate with a short example:

A website provider puts into place a script that will block content from being visible except for a request to accept cookies and the information about which cookies are being set and for what purposes data will be processed. There is no possibility to access the content without clicking on the ‘Accept cookies’ button. Since the data subject is not presented with a genuine choice, its consent is not freely given.¹²¹

The guidance also makes it clear that where the data controller leverages an imbalance of power consent cannot be said to be freely given for ‘consent will not be free in cases where there is any element of compulsion, pressure or inability to exercise free will’.¹²²

p. 625 The second condition, found in Art.6(1)(a), is that the consent must be given in relation to one or more specific purposes. The point of specific consent is to provide for purpose limitation and to avoid function creep. Purpose limitation is found in Art.5(b): ‘Personal data shall be collected for specified, explicit and legitimate purposes.’ As the EDPB note ‘it goes without saying that specific consent can only be obtained when data subjects are specifically informed about the intended purposes of data use concerning them’.¹²³ If a data controller has gathered data for one purpose and wishes to use it for ↵ another purpose they must seek additional consent unless there is another lawful basis allowing them to process the data.¹²⁴

The consent must be informed which is otherwise known as the transparency requirement. As the EDPB note, 'based on Article 5 of the GDPR, the requirement for transparency is one of the fundamental principles, closely related to the principles of fairness and lawfulness.'¹²⁵ Helpfully the guidelines set out the minimum requirements for consent to be informed. They are that the data subject is informed of:

1. the controller's identity
2. the purpose of each of the processing operations for which consent is sought,
3. what (type of) data will be collected and used,
4. the existence of the right to withdraw consent,
5. information about the use of the data for automated decision-making in accordance with Article 22(2) (c) where relevant, and
6. on the possible risks of data transfers due to absence of an adequacy decision and of appropriate safeguards as described in Article 46.¹²⁶

In terms of how this information is presented, the guidance is clear that 'when seeking consent, controllers should ensure that they use clear and plain language in all cases. This means a message should be easily understandable for the average person and not only for lawyers' and that 'consent must be clear and distinguishable from other matters and provided in an intelligible and easily accessible form. This means that information relevant for making informed decisions on whether or not to consent may not be hidden in general terms and conditions.'¹²⁷ To be transparent the information given must be clear, free from legal jargon, and easily accessible and visible to the user.

The final requirement is that the consent be unambiguous. As the guidance makes clear 'consent requires a statement from the data subject or a clear affirmative act, which means that it must always be given through an active motion or declaration.'¹²⁸ The guidance is clear that a 'clear affirmative act' demands that the data subject must have taken a 'deliberate action to consent to the particular processing'.¹²⁹ This negates some forms of action as a way to ingather consent. As the guidance notes, 'consent cannot be obtained through the same motion as agreeing to a contract or accepting general terms and conditions of a service' and 'GDPR does not allow controllers to offer pre-ticked boxes or opt-out constructions that require an intervention from the data subject to prevent agreement.'¹³⁰

p. 626 Children are a special case. By Art.8(1) UK GDPR where an information society service (including any social media or communications service) is offered to a child, being a person under the age of 13, processing of the personal data of that child shall only be lawful if the consent is given not by the child but by 'the holder of parental responsibility over the child'.¹³¹ By Art.8(2) the data controller is required to 'make reasonable efforts to verify in such cases that consent is given or authorised by the holder of parental responsibility over the child, taking into consideration available technology.' This means the data controller has to take steps to attempt to identify when young people are under 13 (in the UK) and to ensure that proper consent has been given. Recital 38 explains why:

Children merit specific protection with regard to their personal data, as they may be less aware of the risks, consequences and safeguards concerned and their rights in relation to the processing of personal data. Such specific protection should, in particular, apply to the use of personal data of children for the purposes of marketing or creating personality or user profiles and the collection of personal data with regard to children when using services offered directly to a child.

22.3.2 Other conditions for the processing of data

Although many talk of the GDPR as being a consent-based model,¹³² consent is not the only condition under which processing will be fair and lawful. Article 6 has a number of additional conditions for processing, most of which allow for the usual functioning of pre-existing legal obligations such as the right to process to conclude or perform a contract,¹³³ or the right to process to comply with a legal obligation,¹³⁴ or in the public interest or in the exercise of official authority.¹³⁵

p. 627 Two interesting conditions are Art.6(1)(d): processing in the vital interests of the data subject and Art.6(1)(f): processing necessary for the purposes of legitimate interests pursued by the data controller. Recital 46 gives more detail as to what are meant by 'vital interests'. We are told 'the processing of personal data should also be regarded to be lawful where it is necessary to protect an interest which is essential for the life of the data subject or that of another natural person'. The ICO in their guidance explain 'it is likely to be particularly relevant for emergency medical care, when you need to process personal data for medical purposes but the individual is incapable of giving consent to the processing'.¹³⁶ Recital 46 notes that 'some types of processing may serve both important grounds of public interest and the vital interests of the data subject as ↵ for instance when processing is necessary for humanitarian purposes, including for monitoring epidemics and their spread or in situations of humanitarian emergencies, in particular in situations of natural and man-made disasters'.¹³⁷

Legitimate interest is probably the most interesting ground excepting consent. This allows the data controller to process data without specific consent where processing is 'necessary for the purposes of the legitimate interests pursued by the controller or by a third party'. This is the only point in the conditions for processing where specifically the interests of a third party, or of the data controller, are acknowledged. Again, the recitals give some guidance. Recital 47 states 'such legitimate interest could exist for example where there is a relevant and appropriate relationship between the data subject and the controller in situations such as where the data subject is a client or in the service of the controller'. It is noticeable that this guidance is less precise than that given in relation to the other conditions, and indeed Recital 47 states 'the existence of a legitimate interest would need careful assessment including whether a data subject can reasonably expect at the time and in the context of the collection of the personal data that processing for that purpose may take place'. The ICO gives further guidance noting 'legitimate interests is the most flexible lawful basis for processing, but you cannot assume it will always be the most appropriate. It is likely to be most appropriate where you use people's data in ways they would reasonably expect and which have a minimal privacy impact, or where there is a compelling justification for the processing'.¹³⁸

p. 628

The CJEU has given some guidance (albeit in relation to the Data Protection Directive rather than GDPR) in the case of *Rigas Satiksme*.¹³⁹ This was a rather unusual case factually. There had been an accident involving a taxi and a trolleybus in Riga. As the trolleybus was passing alongside the taxi, a passenger sitting in the back seat of that taxi opened the door, which scraped against and damaged the trolleybus. The trolleybus operator Rigas Satiksme sought damages from the insurance company of the taxi driver but they refused to pay out as the passenger had caused the damage. They then asked the national police for access to reports taken after the incident to pursue civil proceedings against the driver and/or their passenger. The national police responded in part by giving Rigas Satiksme the name of the passenger but nothing more. The reasoning of the police was that documents in the case file in administrative proceedings leading to sanctions may be provided only to the parties to those proceedings. Rigas Satiksme applied to the District Administrative Court, Latvia for the information and following appeals the case was referred to the CJEU by the Supreme Court of Latvia. The court asked the CJEU:

Must the phrase ‘is necessary for the purposes of the legitimate interests pursued by the ... third party or parties to whom the data are disclosed’, in Article 7(f) of Directive 95/46/EC, be interpreted as meaning that the national police must disclose to Rigas Satiksme the personal data sought which are necessary for civil proceedings to be initiated?¹⁴⁰

The court set out three cumulative conditions to meet the legitimate interest standard under the DPD (the purpose, necessity, and balancing test). The first is that there must be pursuit of a legitimate interest: ‘there is no doubt that the interest of a third party in obtaining the personal information of a person who damaged their property in order to sue that person for damages can be qualified as a legitimate interest.’¹⁴¹ Second, there must be necessity to obtain the data: ‘it should be borne in mind that derogations and limitations in relation to the protection of personal data must apply only in so far as is strictly necessary. Communication of merely the first name and surname of the person who caused the damage does not make it possible to identify that person with sufficient precision in order to be able to bring an action against him. Accordingly, it is necessary to obtain also the address and/or the identification number of that person.’¹⁴² Finally, there must be the balancing of the rights and interests of the parties. This we are told, ‘depends in principle on the specific circumstances of the particular case’ and one must take into consideration ‘the fact that the seriousness of the infringement of the data subject’s fundamental rights resulting from that processing can vary depending on the possibility of accessing the data at issue in public sources.’¹⁴³ One factor in the balancing of interests in this case was the age of the data subject who from reports was a minor. The court concluded that this was something to be considered but did not displace the interests of the applicant. They found that ‘Article 7(f) of Directive 95/46 must be interpreted as not imposing the obligation to disclose personal data to a third party in order to enable him to bring an action for damages before a civil court for harm caused by the person concerned by the protection of that data. However, Article 7(f) of that directive does not preclude such disclosure on the basis of national law’¹⁴⁴ a rather open-ended outcome which passed the balancing question back to the national court.

22.4 Conclusions

p. 629 This chapter has covered a lot of ground. Data protection is one of the pre-eminent areas of practice for technology lawyers and of study for students of technology law. There are books which can give you more detail¹⁴⁵ and I recommend that for those seeking specialist knowledge of this expansive and complex area they seek out these texts. This chapter has set out some of the key issues of the GDPR framework post-Brexit. The slightly complex relationship between UK and EU GDPR, the territorial scope of the GDPR framework, who the key parties are and what personal data is and what are the conditions for processing of personal data. In the next chapter we will take these concepts forward, looking at the rights of data subjects and the obligations of data controllers. The practical duties if you will of the framework we have discussed in this chapter.

Test Questions

Question 1

Marie is a keen, if unsuccessful, blogger (with a very limited following) who writes mostly about online gambling. Marie's most recent blogs wants to dispel the myth that online gamblers are addicts. She describes a number of her friends—a reputable dentist living in the Kensington area, a journalist who has recently been nominated for a prestigious award, and a teacher in a primary school close to Marie's home and outlines how they use online gambling sites for multiple purposes including socializing with other gamblers. Although Marie does not name these individuals, she is contacted by one of them and asked to edit her blog post to remove some of this information. She refuses and her friend complains to the Information Commissioner's Office (ICO). When investigating the ICO also realizes that Marie is an avid 'Go-Pro' user and posts her 'Go-Pro' footage, filmed all over London, on her blog.

Marie seeks your advice as to whether she is in fact processing personal data within the meaning of data protection law and, if so, whether there are any exemptions that she could invoke to avoid data protection regulation.

Question 2

In the current setting, the broad definitions of personal data, processing of personal data and controller are likely to cover an unprecedented wide range of new factual situations due to technological development. The scope of EU data protection law is therefore too broad and should have been limited in the data protection reform process.

Discuss.

Further Reading

Books

L Bygrave, *Data Privacy Law: An International Perspective* (OUP, 2014)

P Carey, *Data Protection: A Practical Guide to UK Law* (OUP 2020)

C Kuner et al., *The EU General Data Protection Regulation* (OUP 2020)

O Lynskey, *The Foundations of EU Data Protection Law* (OUP 2015)

p. 630 Chapters and articles

F Borgesius et al., 'Tracking Walls, Take-It-Or-Leave-It Choices, the GDPR, and the ePrivacy Regulation' (2017) 3 *European Data Protection Law* 353

L Dalla Corte, 'Scoping Personal Data: Towards a Nuanced Interpretation of the Material Scope of EU Data Protection Law' (2019) 10(1) *European Journal of Law and Technology*

B-J Koops, 'The Trouble with European Data Protection Law' (2014) 4 *International Data Privacy Law* 250

I Lloyd, 'From Ugly Duckling To Swan: The Rise of Data Protection and its Limits' (2018) 34 *Computer Law & Security Review* 779

N Purtova, 'The Law of Everything. Broad Concept of Personal Data and Future of EU Data Protection Law' (2018) 10 *Law, Innovation and Technology* 40

Notes

¹ K Poynter, *Review of Information Security at HM Revenue and Customs: Final Report* (HMSO 2008) https://ntouk.files.wordpress.com/2015/06/poynter_review250608.pdf <https://ntouk.files.wordpress.com/2015/06/poynter_review250608.pdf>.

² H Mulholland, 'Details of 3m Learner Drivers Lost, Government Admits', *The Guardian*, 17 December 2007.

³ D Rose, 'More Personal Data Lost as Nine NHS Trusts Admit Security Breaches', *The Times*, 24 December 2007.

⁴ J Ungood-Thomas, 'More Financial Data Discs Lost', *The Times*, 2 December 2007.

⁵ Famously lampooned in the Little Britain sketch 'computer says no'. For those on the receiving end of a computerized decision-making process though there is little to laugh about. See O Osoba and W Welser, *An Intelligence in Our Image: The Risks of Bias and Errors in Artificial Intelligence* (Rand 2017).

⁶ A Daly, *Private Power, Online Information Flows and EU Law: Mind The Gap* (Hart 2016); P Bernal, *Internet Privacy Rights: Rights to Protect Autonomy* (CUP 2014).

⁷ S Joseph and R Shields, 'The Rundown: Google, Meta and Amazon re on Track to Absorb More than 50% of all Ad Money in 2022', *Digiday*, 4 February 2022 <https://digiday.com/marketing/the-rundown-google-meta-and-amazon-are-on-track-to-absorb-more-than-50-of-all-ad-money-in-2022/> <<https://digiday.com/marketing/the-rundown-google-meta-and-amazon-are-on-track-to-absorb-more-than-50-of-all-ad-money-in-2022/>>.

⁸ Directive 95/46/EC.

⁹ 2000/C 364/01.

¹⁰ Art.8(1).

¹¹ Although agreed in 2000 the Charter did not become legally binding until the entry into force of the Treaty of Lisbon, in December 2009. See 2012/C 326/02.

¹² The original factsheet is no longer available, however some of the themes may be seen in the European Commission's *Data Protection Reform: Frequently Asked Questions* at https://ec.europa.eu/commission/presscorner/detail/en/MEMO_12_41 <https://ec.europa.eu/commission/presscorner/detail/en/MEMO_12_41>.

¹³ COM(2012) 11 final (Brussels, 25 January 2012).

¹⁴ As for example in *Google Spain SL and Google Inc. v AEPD* ECLI:EU:C:2014:317.

¹⁵ COM(2012), 11.

¹⁶ (EU) 2016/679.

¹⁷ <https://bills.parliament.uk/bills/3322> <<https://bills.parliament.uk/bills/3322>>.

¹⁸ s.6(3).

¹⁹ s.6(4)(a).

²⁰ EU Commission, Adequacy decision on the United Kingdom (GDPR) C (2021) 4800 final.

²¹ <https://www.ukpol.co.uk/michelle-donelan-2022-speech-to-conservative-party-conference/> <<https://www.ukpol.co.uk/michelle-donelan-2022-speech-to-conservative-party-conference/>>.

²² J Maude, R Easton, and D Stander, 'The End of UK GDPR?' Volume XII (290) *The National Law Review* 17 October 2022.

²³ Council of Europe, CETS 108.

²⁴ Data Protection Directive, Art.4(1).

²⁵ *Weltimmo s.r.o. v Nemzeti Adatvédelmi és Információszabadság Hatóság* ECLI:EU:C:2015:639.

²⁶ *Ibid*, [29].

²⁷ n.14.

²⁸ *Ibid*, [56].

²⁹ *Ibid*, [52].

³⁰ *Ibid*, [53].

³¹ *Ibid*, [55].

³² Guidelines 3/2018 on the territorial scope of the GDPR Ver.2.1 issued 7 January 2020. Post Brexit these are not binding on UK courts but are influential, as shall be seen below.

³³ Ibid, 6.

³⁴ Ibid, 7–8.

³⁵ Ibid, 9.

³⁶ Ibid, 14–15.

³⁷ Ibid, 16–17.

³⁸ As per the judgment of the CJEU in *Heller* ECLI:EU:C:2010:740.

³⁹ n.32, 20.

⁴⁰ Ibid.

⁴¹ Ibid, 22.

⁴² SI 2019/419.

⁴³ *Soriano v Forensic News LLC* [2021] EWCA Civ 1952, [73].

⁴⁴ The *Amazon* case is *Verein für Konsumenteninformation v Amazon EU Sarl* ECLI:EU:C:2016:612.

⁴⁵ n.43, [87].

⁴⁶ Ibid, [96].

⁴⁷ Ibid, [97].

⁴⁸ Ibid, [98].

⁴⁹ Ibid, 100] emphasis in the original.

⁵⁰ Ibid.

⁵¹ Ibid, [101].

⁵² Ibid.

⁵³ Ibid, [102].

⁵⁴ Ibid.

⁵⁵ Ibid.

⁵⁶ I De Freitas and A Matthews, ‘Ruling Threatens to Extend the Extra-Territorial Reach of GDPR’, *Insight* 3 February 2022 <https://www.farrer.co.uk/news-and-insights/ruling-threatens-to-extend-the-extra-territorial-reach-of-gdpr/> <<https://www.farrer.co.uk/news-and-insights/ruling-threatens-to-extend-the-extra-territorial-reach-of-gdpr/>>.

⁵⁷ Dechert LLP, *UK Court of Appeal Considers Territorial Scope of GDPR* <https://www.dechert.com/knowledge/onpoint/2022/1/uk-court-of-appeal-considers-territorial-scope-of-gdpr.html> <<https://www.dechert.com/knowledge/onpoint/2022/1/uk-court-of-appeal-considers-territorial-scope-of-gdpr.html>>.

⁵⁸ Ibid. At time of writing there appears to be no hearing set down for the full trial. An application for discovery was made by Forensic News LLC in the Southern District of New York on 23 August 2022 in relation to their ‘defense of a defamation action filed in England by British-Israeli “security consultant” Walter Soriano’. A full hearing may be some time away assuming the parties do not settle.

⁵⁹ Recital 14 EU GDPR.

⁶⁰ IP completion day is a phrase seen frequently in adapted legislation post-Brexit. It means the Implementation Period completion day which is 11 months from Brexit Day. It means therefore in effect 31 December 2020.

⁶¹ Art.4(5) defines ‘pseudonymisation’ as ‘the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person’.

⁶² Information Commissioner’s Office, *What is Personal Data?* <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/key-definitions/what-is-personal-data/> ~~<https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/key-definitions/what-is-personal-data/>~~.

⁶³ Ibid.

⁶⁴ [2004] FSR 28.

⁶⁵ Ibid, [80].

⁶⁶ L Edwards, ‘Taking the “Personal” Out of Personal Data: Durant v FSA and its Impact on the Legal Regulation of CCTV’ (2004) 1 *SCRIPT-ed* 342; S Chalton, ‘The Court of Appeal’s Interpretation of “Personal Data” in Durant v FSA – A Welcome Clarification, or a Cat Amongst the Data Protection Pigeons?’ (2004) 20 *Computer Law & Security Review* 175.

⁶⁷ Article 29 Working Party, *Opinion 4/2007 on the Concept of Personal Data*, 9.

⁶⁸ Ibid, 9.

⁶⁹ Ibid, 10.

⁷⁰ Ibid, 11.

⁷¹ [2014] EWCA Civ 92.

⁷² Information Commissioner’s Office, *Determining What is Personal Data* (ICO 2012). This has since been replaced with the guidance at n.62.

⁷³ n.71, [21].

⁷⁴ ECLI:EU:C:2017:994.

⁷⁵ ECLI:EU:C:2013:838, [56]

⁷⁶ n.74, [37].

⁷⁷ Ibid, [38].

⁷⁸ Ibid, [39].

⁷⁹ Ibid, [44].

⁸⁰ *Patrick Breyer v Bundesrepublik Deutschland* ECLI:EU:C:2016:779.

⁸¹ *Ibid*, [49].

⁸² n.74, [31].

⁸³ In this section all definitions taken from Art.4 UK GDPR.

⁸⁴ *Unabhängiges Landeszentrum für Datenschutz Schleswig-Holstein v Wirtschaftsakademie Schleswig-Holstein GmbH* ECLI:EU:C:2018:388.

⁸⁵ At [27]. Note this is the same definition found at Art.4(7) of UK GDPR.

⁸⁶ *Ibid*, [28].

⁸⁷ *Ibid*, [30].

⁸⁸ *Ibid*, [35].

⁸⁹ *Ibid*, [36].

⁹⁰ *Ibid*, [43].

⁹¹ UK GDPR Art.4(8).

⁹² Admittedly Dunnhumby is a wholly owned subsidiary of Tesco plc but in law (and in data protection terms) it is a separate legal entity.

⁹³ Art.28(1).

⁹⁴ Art.28(2).

⁹⁵ Ss.35(8) and 42, and Schs.8 and 10.

⁹⁶ Art.4(6).

⁹⁷ ECLI:EU:C:2003:596.

⁹⁸ EU GDPR Art.2(2)(c); UK GDPR Art.2(2)(a).

⁹⁹ n.97, [47].

¹⁰⁰ ECLI:EU:C:2014:2428.

¹⁰¹ *Ibid*, [18]. Note: Art.2(2)(c) of EU GDPR/Art.2(2)(a) of UK GDPR extends the domestic processing exemption into the modern framework.

¹⁰² *Ibid*, [22].

¹⁰³ *Ibid*, [25].

¹⁰⁴ n.14.

¹⁰⁵ n.100, [28].

¹⁰⁶ *Ibid*, [31]–[33].

¹⁰⁷ *Ibid*, [34].

¹⁰⁸ [2007] EWCA Civ 262.

¹⁰⁹ *Ibid*, [2].

¹¹⁰ *Ibid*.

¹¹¹ *Johnson v The Medical Defence Union Ltd* [2006] EWHC 321 (Ch).

¹¹² *Ibid*, [110].

¹¹³ *Ibid*, [202].

¹¹⁴ n.108, [145].

¹¹⁵ *Ibid*, [148]–[149].

¹¹⁶ *Ibid*, [72].

¹¹⁷ EDPB, *Guidelines 05/2020 on Consent under Regulation 2016/679* 4 May 2020 https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_en.pdf <https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_en.pdf>.

¹¹⁸ *Ibid*, [13].

¹¹⁹ *Ibid*, [38].

¹²⁰ *Ibid*, [39].

¹²¹ *Ibid*, [40].

¹²² *Ibid*, [24].

¹²³ *Ibid*, [57].

¹²⁴ *Ibid*, [59].

¹²⁵ *Ibid*, [62].

¹²⁶ *Ibid*, [64].

¹²⁷ *Ibid*, [67].

¹²⁸ *Ibid*, [75].

¹²⁹ *Ibid*, [77].

¹³⁰ *Ibid*, [81].

¹³¹ In EU GDPR a child is defined as a person under the age of 16 (with an option for Member States to elect to instead choose 13).

¹³² See E Carolan, 'The Continuing Problems with Online Consent Under the EU's Emerging Data Protection Principles' (2016) 32 *Computer Law & Security Review* 462; T Zarsky, 'Incompatible: The GDPR in the Age of Big Data' [2017] 47 *Seton Hall Law Review* 995.

¹³³ This may be relied upon if the data controller needs to process the data subject's personal data to fulfill a contractual obligation to them; or because they have been asked to do something before entering into a contract (e.g. provide a quote).

¹³⁴ This applies when the data controller is obliged to process the personal data to comply with the law. An example would be where an employer needs to process personal data to comply with its legal obligation to disclose employee salary details to HMRC.

¹³⁵ This applies when it is necessary process personal data ‘in the exercise of official authority’ or to perform a specific task in the public interest that is set out in law. Examples include HMRC’s calculations of tax due to be paid or the operation of the DVLA driver database.

¹³⁶ <https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/vital-interests/> <<https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/vital-interests/>>.

¹³⁷ Interestingly, when the Covid-19 pandemic hit the EDPB issued guidelines on both the use of personal data for scientific research and for contact tracing. Although Recital 46 explicitly mentions ‘monitoring epidemics’ it was not cited in either guidance. In fact, except for a quick reference in the statement by the EDPB Chair on the processing of personal data in the context of the COVID-19 outbreak on 16 March 2020, Recital 46 was noticeably absent from EDPB advice and guidance throughout the pandemic. This caused some heated academic debate on the status of contact tracing and other health monitoring programmes under GDPR. See L Bradford, M Aboy, and K Liddell, ‘COVID-19 Contact Tracing Apps: A Stress Test for Privacy, the GDPR, and Data Protection Regimes’ (2020) 7 *Journal of Law and the Biosciences* Isaa034; A Guinchard, ‘Our Digital Footprint under Covid-19: Should We Fear the UK Digital Contact Tracing App?’ (2021) 35 *International Review of Law, Computers & Technology* 84; cf M Leiser and MM Caruana, ‘Some Contrarian Thoughts on the Deployment of Contact-Tracing Apps’ SSRN <https://ssrn.com/abstract=3608677> <<https://ssrn.com/abstract=3608677>>.

¹³⁸ <https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/legitimate-interests/> <<https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/legitimate-interests/>>.

¹³⁹ *Valsts policijas Rīgas reģiona pārvaldes Kārtības policijas pārvalde v Rīgas pašvaldības SIA ‘Rīgas satiksme’* ECLI:EU:C:2017:336.

¹⁴⁰ *Ibid*, [22].

¹⁴¹ *Ibid*, [29].

¹⁴² *Ibid*, [30].

¹⁴³ *Ibid*, [32].

¹⁴⁴ *Ibid*, [34].

¹⁴⁵ See e.g. P Carey, *Data Protection: A Practical Guide to UK Law* (OUP 2020); C Kuner et al., *The EU General Data Protection Regulation (GDPR): A Commentary* (OUP 2020).

Find This Title

In the OUP print catalogue [_<https://global.oup.com/academic/product/9780192893529>](https://global.oup.com/academic/product/9780192893529)